

☒ Easy (10 Questions)

1.

What does OWASP stand for?

- A) Open Web Application Security Project
- B) Online Web Application Security Program
- C) Open Wireless Access Security Protocol
- D) Official Web Application Service Provider

2.

Which of the following is a common web app security risk?

- A) Injection
- B) Data Backup
- C) Load Balancing
- D) DNS Caching

3.

What is the primary goal of input validation?

- A) To prevent invalid or malicious data from entering the system
- B) To increase database size
- C) To speed up network traffic
- D) To enhance graphical UI

4.

What does the HTTP header Content-Security-Policy help prevent?

- A) SQL Injection
- B) Cross-Site Scripting (XSS)
- C) Man-in-the-Middle attacks
- D) Data encryption

5.

Burp Suite is mainly used for:

- A) Writing web code
- B) Testing web application security
- C) Managing databases
- D) Deploying servers

6.

Which HTTP header can force browsers to use HTTPS connections?

- A) X-Frame-Options
- B) Strict-Transport-Security
- C) Cache-Control
- D) User-Agent

7.

What is a proxy in Burp Suite used for?

- A) To intercept HTTP requests and responses
- B) To speed up loading time
- C) To compress images
- D) To host websites

8.

What does threat modeling help organizations do?

- A) Identify and prioritize security risks
- B) Write marketing materials
- C) Manage employee schedules
- D) Monitor server uptime

9.

Which HTTP header can prevent clickjacking attacks?

- A) X-Content-Type-Options
- B) X-Frame-Options
- C) Set-Cookie
- D) Cache-Control

10.

What is the purpose of the Burp Suite Repeater tool?

- A) To repeat network scans automatically
- B) To manually modify and resend HTTP requests
- C) To store cookies securely
- D) To encrypt traffic

☒ Medium (20 Questions)

11.

Which of the following is NOT an OWASP Top 10 risk?

- A) Injection
- B) Broken Authentication
- C) Data Encryption
- D) Security Misconfiguration

12.

What does SAST stand for in application security testing?

- A) Static Application Security Testing
- B) Secure Application System Testing
- C) Standardized Application Security Techniques
- D) Simple Application Security Tools

13.

Which HTTP header attribute improves cookie security by restricting access to client-side scripts?

- A) Secure
- B) HttpOnly
- C) SameSite
- D) Max-Age

14.

What is a typical use case for Burp Suite Intruder?

- A) Running automated vulnerability scans
- B) Performing brute-force or fuzzing attacks on input fields
- C) Editing source code
- D) Managing SSL certificates

15.

In threat modeling, what does STRIDE stand for?

- A) Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege
- B) Security, Threats, Risks, Identification, Data, Evaluation
- C) Systems, Threats, Risk, Identification, Design, Execution
- D) Spoofing, Threats, Risks, Integrity, Denial, Exploits

16.

Which Burp Suite tool can automatically map out a web application's pages?

- A) Intruder
- B) Spider
- C) Repeater
- D) Decoder

17.

What type of testing involves analyzing running applications for vulnerabilities?

- A) Static Application Security Testing (SAST)
- B) Dynamic Application Security Testing (DAST)
- C) Code Review
- D) Unit Testing

18.

Which HTTP header prevents browsers from MIME sniffing a response away from the declared content-type?

- A) X-Content-Type-Options
- B) X-Frame-Options
- C) Cache-Control
- D) Content-Security-Policy

19.

What is the role of the Burp Suite Sequencer?

- A) Decode encoded data

- B) Analyze randomness of session tokens
- C) Intercept HTTP requests
- D) Perform brute-force attacks

20.

What does the Burp Suite Scanner tool primarily do?

- A) Perform automated vulnerability scans
- B) Edit HTTP headers
- C) Crawl website pages
- D) Manage certificates

21.

What is a common method used in threat modeling to classify threats?

- A) DREAD
- B) OWASP
- C) HTTP
- D) SSL

22.

Which of the following is a risk from not validating user input?

- A) SQL Injection
- B) Load Balancing
- C) DNS Caching
- D) Data Backup

23.

What kind of attack does the HTTP header X-Frame-Options help prevent?

- A) Clickjacking
- B) Man-in-the-Middle
- C) SQL Injection
- D) Brute Force

24.

What is the primary function of the Burp Suite Decoder tool?

- A) Encode and decode data formats
- B) Intercept requests
- C) Run automated scans
- D) Map out site structure

25.

Which HTTP header attribute restricts cookies to same-site requests only?

- A) Secure
- B) HttpOnly
- C) SameSite
- D) Max-Age

26.

In threat modeling, which factor helps prioritize risks?

- A) Risk likelihood and impact
- B) User popularity
- C) Developer skill level
- D) Network bandwidth

27.

Which Burp Suite feature helps automate attacks on user inputs?

- A) Proxy
- B) Intruder
- C) Repeater
- D) Sequencer

28.

Which header controls browser caching behavior?

- A) Cache-Control
- B) X-Frame-Options
- C) Content-Security-Policy
- D) Set-Cookie

29.

What does a Content-Security-Policy header allow you to specify?

- A) Allowed sources for scripts, styles, and other resources
- B) User authentication methods
- C) Database connection settings
- D) Network IP ranges

30.

What is an important step when identifying application security risks?

- A) Reviewing application architecture and data flows
- B) Increasing server RAM
- C) Improving UI design
- D) Adding more features

☒ Hard (10 Questions)

31.

In threat modeling, what is the primary purpose of Data Flow Diagrams (DFDs)?

- A) Visualize data movement and trust boundaries in the system
- B) Write test scripts
- C) Map server hardware
- D) Configure firewalls

- 32.
- Which Burp Suite tool helps analyze the quality of randomness in session tokens to detect weak session management?
- A) Intruder
 - B) Sequencer
 - C) Spider
 - D) Repeater
- 33.
- What is a common limitation of static application security testing (SAST)?
- A) Cannot analyze runtime behaviors
 - B) Requires internet connection
 - C) Only works on encrypted apps
 - D) Can only be used for mobile apps
- 34.
- What does the Strict-Transport-Security header prevent?
- A) Session fixation
 - B) HTTPS downgrade attacks
 - C) Cross-site scripting
 - D) SQL injection
- 35.
- How can an attacker exploit improper use of the Set-Cookie header?
- A) Session hijacking if cookies are not set as HttpOnly and Secure
 - B) Denial of Service
 - C) Cross-site scripting
 - D) Network sniffing
- 36.
- Which of the following best describes the difference between discretionary access control (DAC) and mandatory access control (MAC)?
- A) DAC is controlled by the owner; MAC is controlled by system policy
 - B) DAC is hardware-based; MAC is software-based
 - C) DAC is used in databases; MAC is used in networking
 - D) DAC applies to users; MAC applies to groups
- 37.
- What Burp Suite feature allows you to customize and automate complex attack payloads?
- A) Spider
 - B) Intruder
 - C) Decoder
 - D) Repeater
- 38.
- Which HTTP header could be used by attackers to perform Cross-Site Scripting if not properly validated?

- A) User-Agent
- B) Referer
- C) Cookie
- D) All of the above

39.

How does Content Security Policy mitigate Cross-Site Scripting attacks?

- A) By restricting sources of executable scripts and resources
- B) By encrypting cookies
- C) By disabling JavaScript
- D) By blocking IP addresses

40.

What is the main benefit of using threat modeling early in the software development lifecycle?

- A) Proactively identifying and mitigating risks before implementation
- B) Writing better documentation
- C) Increasing server speed
- D) Reducing code size

1. What does OWASP stand for?

- A) Open Web Application Security Project
- B) Online Web Application Security Program
- C) Open Wireless Access Security Protocol
- D) Official Web Application Service Provider

☒ Answer: A

Explanation: OWASP is the Open Web Application Security Project, focused on improving software security.

2. Which of the following is a common web app security risk?

- A) Injection
- B) Data Backup
- C) Load Balancing
- D) DNS Caching

☒ Answer: A

Explanation: Injection attacks (e.g., SQL Injection) are listed in the OWASP Top 10 security risks.

3. What is the primary goal of input validation?

- A) To prevent invalid or malicious data from entering the system
- B) To increase database size
- C) To speed up network traffic
- D) To enhance graphical UI

☒ Answer: A

Explanation: Input validation prevents security issues by rejecting unexpected or malicious inputs.

4. What does the HTTP header Content-Security-Policy help prevent?

- A) SQL Injection
- B) Cross-Site Scripting (XSS)
- C) Man-in-the-Middle attacks
- D) Data encryption

☒ Answer: B

Explanation: Content-Security-Policy restricts the sources of content, mitigating XSS.

5. Burp Suite is mainly used for:

- A) Writing web code
- B) Testing web application security
- C) Managing databases
- D) Deploying servers

☒ Answer: B

Explanation: Burp Suite is a popular tool for testing the security of web applications.

6. Which HTTP header can force browsers to use HTTPS connections?

- A) X-Frame-Options
- B) Strict-Transport-Security
- C) Cache-Control
- D) User-Agent

☒ Answer: B

Explanation: Strict-Transport-Security instructs browsers to connect only via HTTPS.

7. What is a proxy in Burp Suite used for?

- A) To intercept HTTP requests and responses
- B) To speed up loading time
- C) To compress images
- D) To host websites

☒ Answer: A

Explanation: Burp's proxy allows users to inspect and modify web traffic.

8. What does threat modeling help organizations do?

- A) Identify and prioritize security risks
- B) Write marketing materials
- C) Manage employee schedules
- D) Monitor server uptime

☒ Answer: A

Explanation: Threat modeling is used to anticipate and prioritize security threats.

9. Which HTTP header can prevent clickjacking attacks?

- A) X-Content-Type-Options
- B) X-Frame-Options
- C) Set-Cookie
- D) Cache-Control

☒ Answer: B

Explanation: X-Frame-Options prevents your page from being framed, blocking clickjacking.

10. What is the purpose of the Burp Suite Repeater tool?

- A) To repeat network scans automatically
- B) To manually modify and resend HTTP requests
- C) To store cookies securely
- D) To encrypt traffic

☒ Answer: B

Explanation: Repeater lets users replay and manipulate individual HTTP requests.

☒ Medium (20 Questions)

11. Which of the following is NOT an OWASP Top 10 risk?

- A) Injection
- B) Broken Authentication
- C) Data Encryption
- D) Security Misconfiguration

☒ Answer: C

Explanation: Data encryption is a practice, not a defined OWASP Top 10 risk.

12. What does SAST stand for in application security testing?

- A) Static Application Security Testing

☒ Answer: A

Explanation: SAST is a white-box testing method that scans source code for vulnerabilities.

13. Which HTTP header improves cookie security by restricting access to client-side scripts?

- A) Secure
- B) HttpOnly
- C) SameSite
- D) Max-Age

☒ Answer: B

Explanation: HttpOnly prevents JavaScript from accessing cookies.

14. Typical use case for Burp Suite Intruder?

- A) Performing brute-force or fuzzing attacks on input fields

☒ Answer: B

Explanation: Intruder automates attack payloads and helps in brute-force testing.

15. What does STRIDE stand for in threat modeling?

☒ Answer: A

Explanation: STRIDE: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege.

16. Which Burp Suite tool can automatically map out a web application's pages?

☒ Answer: B (Spider)

Explanation: The Spider tool crawls applications to discover all endpoints.

17. What type of testing is DAST?

☒ Answer: B (Dynamic Application Security Testing)

Explanation: DAST scans running applications to find vulnerabilities.

18. Which HTTP header prevents MIME sniffing?

☒ Answer: A (X-Content-Type-Options)

Explanation: It ensures browsers interpret content strictly by declared type.

19. Burp Suite Sequencer is used to:

☒ Answer: B

Explanation: Sequencer analyzes randomness in tokens like session IDs.

20. What does Burp Scanner do?

☒ Answer: A

Explanation: Scanner performs automated vulnerability scanning.

21. What is DREAD in threat modeling?

☒ Answer: A

Explanation: DREAD = Damage, Reproducibility, Exploitability, Affected users, Discoverability.

22. What risk results from not validating input?

☒ Answer: A (SQL Injection)

Explanation: Poor input validation leads to injection attacks.

23. What does X-Frame-Options defend against?

☒ Answer: A (Clickjacking)

Explanation: It blocks your site from being embedded in iframes.

24. Burp Decoder tool is used for:

☒ Answer: A

Explanation: It helps decode and encode data (e.g., base64, URL encoding).

25. What restricts cookies to same-site requests?

☒ Answer: C (SameSite)

Explanation: The SameSite attribute prevents cross-origin cookie access.

26. In threat modeling, what helps prioritize risks?

☒ Answer: A (Likelihood and impact)

Explanation: This approach helps determine which risks to address first.

27. Which Burp tool helps automate attacks on inputs?

☒ Answer: B (Intruder)

Explanation: Intruder is for testing input fields at scale.

28. Which HTTP header controls caching behavior?

☒ Answer: A (Cache-Control)

Explanation: It defines how and for how long the response is cached.

29. What does Content-Security-Policy do?

☒ Answer: A

Explanation: It defines allowed sources for scripts, styles, images, etc.

30. Important step in identifying app risks?

☒ Answer: A

Explanation: Analyzing data flows and architecture reveals potential weak spots.

☒ Hard (10 Questions)

31. Primary use of Data Flow Diagrams in threat modeling?

☒ Answer: A

Explanation: DFDs show how data moves and where trust boundaries exist.

32. Burp tool for analyzing session token randomness?

☒ Answer: B (Sequencer)

Explanation: Sequencer ensures session IDs are unpredictable.

33. Limitation of SAST?

☒ Answer: A

Explanation: SAST cannot assess behavior at runtime.

34. What does Strict-Transport-Security prevent?

☒ Answer: B (HTTPS downgrade attacks)

Explanation: It enforces HTTPS to stop MITM downgrade attempts.

35. How can Set-Cookie misuse lead to attacks?

☒ Answer: A

Explanation: Missing HttpOnly or Secure can expose cookies to theft.

36. DAC vs MAC?

☒ Answer: A

Explanation: DAC lets users control access, MAC enforces policy-driven access.

37. Burp feature to automate custom payloads?

☒ Answer: B (Intruder)

Explanation: Intruder is customizable for attack scenarios.

38. Which header can XSS originate from if unsanitized?

☒ Answer: D (All of the above)

Explanation: Any reflected unsanitized header value can trigger XSS.

39. How does CSP mitigate XSS?

☒ Answer: A

Explanation: It restricts where scripts can be loaded from.

40. Why model threats early in SDLC?

☒ Answer: A

Explanation: Early modeling finds and fixes issues before costly deployment.